

Market Adoption of Cybersecurity: A Dynamic Analysis

Pengfei Zhang*

May 29, 2025

Abstract

This paper studies the dynamic (in)efficiency of market adoption of cybersecurity. Individual firms choose whether and when to make a precautionary investment in self-protection against the evolving security risk of direct attack and indirect contagion. The equilibrium adoption path has a “tipping point”: firms will invest to get protected when a critical mass of data breach has been reached. In the special homogeneous model, the market equilibrium path is found to be the socially optimal path in the presence of externalities, which reckons findings in similar models of the vaccination market. I then study five extended models that are more representative of the security industry and show that the efficiency result holds for all of them, including general demand for security, weak targets, in-house security team, security upgrade, and ex-post recovery. The market efficiency result would break down, however, if security-relevant information is not publicly available. The findings caution against security interventions that are purely externality-based and might help to explain why federal and state governments prioritize breach disclosure law over public subsidy programs.

Keywords: Cybersecurity, Security Investment, Externalities, Public Good, Information Asymmetry, Technology Adoption, Botnet, Malware, Optimal Control

*School of Economic, Political and Policy Sciences, The University of Texas at Dallas, pengfei.zhang@utdallas.edu

1 Introduction

The notion of externalities is often invoked to cause market failure in the market for information security ([Anderson and Moore, 2006](#); [Camp and Wolfram, 2004](#); [Gandal, 2007](#); [Van Eeten and Bauer, 2008](#); [Kobayashi, 2006](#)). End users who connect infected personal computers to the Internet may emit spam, host phishing websites, distribute malware or ransomware, and launch denial-of-service attacks, thus creating negative externalities to other users. On the other hand, security investment has a public good problem: a firm taking protective measures may also protect other firms, inviting all of them to free ride. This problem is exacerbated by network effects: if every firm waits for others to go first, the more secure system will never get adopted (as seen in the case of Internet protocols). In all these cases, the market solution of cybersecurity is inefficient, and under-investment or delayed investment in protection would be expected.

There are various forms of government intervention in the market for information security that are grounded on externalities. Some prominent examples are public subsidies, government mandates, and liability rules ([Cordes, 2011](#)). In the US, federal funding and tax credits are provided for businesses to purchase security software, hire security professionals, and cover the cost of training programs ([Committee, 2005](#)). The US Federal Information Security Modernization Act requires federal agencies to develop and implement security programs. In the US, strict liability has been notably imposed on the banking sector for data breaches, identity theft, or other financial frauds. Statutory damages have also been proposed in the EU to hold internet service providers liable if they do not promptly remove compromised machines ([Anderson et al., 2009](#)).

The argument has an intuitive appeal and has received formal support in several pioneering models ([Kunreuther and Heal, 2003](#); [Varian, 2004](#); [Lelarge, 2009](#)). However, it remains unclear whether the inefficiency persists and whether government interventions are needed if we consider the full dynamics of the market. This paper fills this gap and examines the validity of this argument through a dynamic welfare analysis of the market adoption of information security. I consider a series of continuous-time models where a population of firms can choose to make a precautionary investment in security at any time. A firm's computer system can get breached in two ways: either by the direct attack of hackers or by the indirect contagion of the previously infected computers (sometimes referred to as the "botnet"). The dynamics of the market are described by a system of nonlinear differential equations analogous to the SI model commonly used in cybersecurity research (and are classical in mathematical biology and network science). I then compare the equilibrium path with the socially optimal outcome, in which the planner's problem

is an optimal control problem.

In the homogeneous model, individual firm's investment decision follows a threshold rule, where the hazard rate of breach must be at least as large as a function of security price and firm characteristics (i.e., profit and interest rate). Consequently, the equilibrium path has a "tipping point": firms will wait until a critical mass of data breach has been reached, at which point the remaining vulnerable firms will all invest to get protected. The demand for cybersecurity thus exhibits network effects in that the economic value of protection grows with the number of harmed participants. Perhaps surprisingly, the optimal path of security adoption is found to be identical to that of the free-market path. Thus, in this special case, externalities do *not* cause market failure. This reckons findings in a seminal work of Francis (1997), which establish the same equivalence in a homogeneous dynamic model of the market of vaccinations.

But the market efficiency result in the homogeneous case raises more questions than providing policy answers. The homogeneous model is, in many aspects, unrealistic for the security industry. Therefore, I study five extended models to incorporate different key characteristics of the security industry to see whether the welfare result is generalizable. The five extended models are general demand for security, weak targets, in-house security team, security upgrade, and ex-post recovery.

The first set of extensions considers heterogeneity in demand and vulnerability. The first exercise is to incorporate heterogeneous demand for security by considering two types of firms with different valuations. In the resulting equilibrium, high valuation firms will get protected in the first phase and low valuation firms will get protected in the second phase. The second exercise is to incorporate differences in vulnerability by considering two types of firms with different vulnerabilities. A group of highly vulnerable firms has a high probability of being attacked, and the rest has a low probability of being attacked. The resulting market equilibrium is such that the weak targets will take precautions earlier than the strong targets.

The second set of extensions considers different ways to model security investment. The first exercise is to incorporate self-selection into internal and external security investment by enabling a firm to get security protection in two ways. The first method is to purchase it at the competitive market price. The second method is to invest in an in-house security team that hires dedicated personnel to discover and fix the bugs. The resulting market equilibrium is such that the outsourcing firms get protected later than the in-house firms. The second exercise is to incorporate the intensive margin of security investment by endowing each firm with two opportunities to in-

vest in security. The first shot protects the firm imperfectly; it reduces the probability of getting breached from high to low. Every firm can make the second investment to upgrade the security, and the second shot reduces the probability of breach to zero. I characterize the timing the firms will make the initial investment and later on upgrade the security endowment.

The third set of extensions considers how ex-post data recovery would affect the incentive for ex-ante precaution. For this purpose, I incorporate recovery from infection ex-post by adding a rate of recovery to the laws of motion such that a firm may recover from infection and become vulnerable again. The hazard rate now depends on both the number of infected and the number of vulnerable. Whether ex-post data recovery crowds out ex-ante precaution depends on how effective the data recovery can be. In a world where recovery is relatively hard and costly, the resulting equilibrium is such that the recovery from infection leads to increased vulnerable firms which reinforces the incentive to get protected.

In all five extended models, the market efficiency result holds: the equilibrium condition is proved to be the same as the planner's optimal control condition.¹ The first two models show that the market efficiency result does not rest on the homogeneity assumption. The third and fourth models show that the efficiency result is robust to how the security investment is modeled. The fifth model shows that the efficiency result is robust to perturbation in the laws of motion. These exercises collectively show that our findings move beyond a mathematical exercise and might deserve serious policy attention.

The key to understanding this result is that unlike conventional public good games, security investment is not strategic substitute in my dynamic model. The fact that some firms make the investment does not remove the incentive for other firms in doing the same. This happens because of the increasing hazard rate of the security breach function. There is the positive externality from security adoption, making the marginal social benefit greater than the marginal private benefit. But there is also the negative externality of insecurity from malware infection, making the marginal social cost greater than the marginal private cost. As a result, individual firm chooses the optimal timing that balances out these two forces, thereby internalizing the external effects of security investment. This result is consistent with Lindahl equilibrium ([Lindahl, 1958](#)) and Coase theorem ([Coase, 1960](#)), which both suggest social optimality can be achieved in market settings in the presence of externalities. The policy implication of the results is this: purely externality-based interventions are at best unnecessary. They may risk distorting the right incentive. If we further

¹For the fifth model, the efficient result is under parametric restrictions.

consider administration costs, they can create pure deadweight loss.

The market efficiency results do hinge on two critical assumptions: (i) *increasing* hazard rate of breach probability, and (ii) all payoff-relevant information is *public*. I conclude by showing one important instance of how the efficiency results would break down - information asymmetry. I consider an incomplete information version of the main model in which firms' vulnerabilities are private information. In this game, firms no longer have accurate expectations of the security risk but instead hold beliefs over the distribution of the possible propagation trajectories. Asymmetric information in the model results in rational delays in security adoption and leads to a Pareto-dominated market outcome. We have a scenario similar to the war of attrition games (e.g., [Alesina and Drazen \(1991\)](#)), in which each firm waits for the other firm to adopt security first, consequently making both firms worse off. The model shows that coupled with asymmetric information, externalities would become a problem that requires government corrections. In this case, breach disclosure laws, rather than public subsidy or liability, might better alleviate the problem. I discuss legislative efforts to transform firms' private information on security breaches and practices into publicly available information.

The remainder of the paper is organized as follows: Section [2](#) reviews the closely related literature. Section [3](#) presents and analyzes the special homogeneous model as a benchmark. Section [4](#) studies the heterogeneous models. Section [5](#) studies the different ways of modeling security investment. Section [6](#) studies the relationship between ex-ante precaution and ex-post recovery. Section [7](#) provides explanations of the efficiency results. Section [8](#) discusses how information asymmetry would break down the market efficiency. Section [9](#) concludes.

2 Related literature

This paper contributes to the growing literature on the economics of information security, in particular, the literature on market failures and the literature on security investment.² The seminal work of [Anderson \(2001\)](#); [Anderson and Moore \(2006\)](#) recognizes that incentive design is as important as technical design in the study of cybersecurity, and identifies several microeconomic concepts, such as externalities, information asymmetry, liability dumping, to explain many insecurity problems. Formal analysis of the externalities problem includes [Kunreuther and Heal](#)

²See [Anderson and Moore \(2006\)](#) for an early overview. See [Arce \(2022\)](#) and [Fedele and Roner \(2022\)](#) for a recent survey of the theoretical literature.

(2003); Varian (2004); Lelarge (2009); Lam (2016). The models highlight that cybersecurity is an interdependent risk such that security protection often depends on the joint efforts of multiple agents. Kunreuther and Heal (2003) models security investments as strategic substitutes: the positive externality of an individual's protective measures may decrease the incentive for their own investment. Varian (2004) studies the free-riding incentive in effort provision that determines system security. He famously distinguishes between three functional forms of security technology: total efforts, weakest link, and best shot. Lam (2016) studies optimal security policy instruments in a model where the firm can make both ex-ante attack-prevention and ex-post damage-control investments. She shows that, very interestingly, full liability can lead to over-investment in damage control and under-investment in attack prevention, and a joint use of a security standard and a partial liability rule may restore efficiency. In her model, the firm's security choices have positive externalities on the users, and therefore would under-invest in the absence of any liability or regulation, because of the free-riding problem. Closely related is Lelarge (2009), which uses a random graph version of epidemic modeling to study malware and security adoption. A theme in this collection of papers is the inefficiency of the equilibrium security due to externalities. It turns out that the dynamic models presented in this paper do not extend the welfare conclusion in the static models. A detailed comparison with Lelarge (2009) is delegated to Section 7.

A classical reference on security investment is Gordon and Loeb (2002), which determines the optimal level of investment based on marginal benefit and marginal cost. They define the probability of a breach as a function of a firm's initial vulnerability and its security investment. Under intuitive restrictions on the behavior of the breach function, they derive an inverted U-shaped relationship between vulnerability and security investment. For intermediate levels of vulnerability, they derive the rule of thumb that investment should never exceed 37 percent ($\approx 1/e$) of the expected loss. Subsequent works Gordon et al. (2003) and Tatsumi and Goto (2010) extend Gordon and Loeb (2002) to model a firm's dynamic security investment using a real option approach. Gordon et al. (2003) introduces a discrete tree model of the finite horizon to study the allocation of a security budget across multiple periods, which is extended in the continuous real options model of Tatsumi and Goto (2010). Firms' equilibrium behavior in my models is consistent with the "wait-and-see approach" in Gordon et al. (2003), which concludes that "it is economically rational to initially invest a portion of the information security budget and defer remaining investments until security breaches actually occur." Another class of models studies the dynamic strategic interactions between an attacker and a defender (Bohme and Moore, 2010; Khouzani et al., 2011; Bensoussan et al., 2010). Khouzani et al. (2011) and Bensoussan et al. (2010), in particular, build

upon dynamic SI models to investigate the optimal attack and defense strategies in a differential game.³ In this collection of papers, the focus is either on a representative firm's optimal investment decision or the best response of a representative defender, instead of the collective action problem of multiple defenders.

This paper complements the aforementioned literature in three aspects. First, it provides a framework for analyzing dynamic (in)efficiency associated with private security decisions, thereby bridging the extant analysis of externalities and dynamic SI modeling on security. Second, it provides a welfare benchmark of the security market (i.e., the equivalence between market outcome and social optimality under complete information) and thereby shows the possible distortionary effects of externality-based interventions. Last but not least, it decouples the two sources of market friction and assesses the relative importance of each friction for security policies.

The idea that externalities do not necessarily lead to market failure dates back to classical works in [Meade \(1952\)](#); [Lindahl \(1958\)](#); [Coase \(1960\)](#); [Arrow \(1969\)](#). But in the framework of dynamic SI modeling, the efficiency result (of the homogeneous case) has first been shown in [Francis \(1997\)](#). [Francis \(1997\)](#) compares the static and dynamic model of vaccination to question the suitability of the static approach. In his elegant dynamic model, he finds that in a homogeneous population, the market equilibrium path coincides with the socially efficient path even in the presence of externalities.⁴ This paper complements [Francis \(1997\)](#) in suggesting that dynamic efficiency in the presence of externalities might be more general than the market of vaccines and of security adoption. There are five key differences between this paper and [Francis \(1997\)](#). First, the fields of study are different. [Francis \(1997\)](#) studies questions on public health, whereas this paper studies incentives in cybersecurity. Second, the laws of motion are different. In [Francis \(1997\)](#), only contagion matters in the state variable of the infection. In this paper, a firm's system can be breached in two ways: the direct attack of hackers, and the indirect contagion of the infected computers. The direct attack α is important in the market dynamics of security markets, which is one of the key distinguishing characteristics of the security industry. When I discuss weak targets in the heterogeneity case, this becomes even more important and delivers insights that are readily seen in any epidemiology model that I am aware of. Third, [Francis \(1997\)](#) established the efficiency of the vaccine market in the homogeneity case, whereas this paper highlights the efficiency in the heterogeneity case and illustrates how different kinds of heterogeneity affect the comparison of the optimal timing. Fourth, [Francis \(1997\)](#) provides intuition on the marginal benefit and marginal

³See [Karyotis and Khouzani \(2016\)](#) for a comprehensive survey on using mathematical models, including epidemic models, to study the diffusion of malware.

⁴See [Chen and Toxvaerd \(2014\)](#) for a discussion on the robustness of [Francis \(1997\)](#)'s results.

cost. This paper interprets the efficiency results in three different veins: two sources of externalities, strategic complement/substitute, personalized prices as in a Lindahl equilibrium. Fifth, this paper also shows how information asymmetry might break the welfare result and connects that with breach disclosure law in the US.

3 A Special Homogeneous Model

In this section, I develop the special homogeneous model of security adoption in parallel with the vaccination model of Francis (1997). For readers who are familiar with the vaccination literature, they can immediately see the similarities and differences between the two markets. For readers who are unfamiliar with the vaccination literature, this section is self-contained and paves the way for subsequent sections.

There are N firms that are identical, have infinite horizons, and do not automatically recover if their systems become compromised.⁵ They value their computer system at a rate v , and they receive a profit of 0 if their systems are breached by malicious codes. They discount future profit at a rate δ . Every firm has one opportunity to invest in security, and they can do that anytime at a price c . Security investment can take various forms. The most obvious one is purchasing anti-virus software. It could also mean a spam filter, a firewall, a cryptographic product, patching, adopting a secure web browser, running applications only from trustworthy sources, etc. The investment is irreversible, and once the investment is made, it will confer permanent protection.⁶

We start with firm i 's individual decision problems. The present discounted value of a firm's profit stream π_i , assuming the system is breached at exactly time t , is

$$\pi_i(t) = \int_0^t v e^{-\delta\tau} d\tau = \frac{v}{\delta} (1 - e^{-\delta t})$$

Denote $P(t)$ as the cumulative probability distribution of getting breached at or before time t . We assume $P(t)$ is differentiable and its derivative is denoted as $P'(t)$. Suppose the firm plans

⁵The homogeneity assumption and the no recovery assumption are relaxed in two of the extensions in Section 4.

⁶The one-shot assumption and the permanent protection assumption are relaxed in two of the extensions in Section 5.

to get the protection at time T_i , the expected present discounted value of the profit would be

$$\mathbb{E}[\pi_i](T_i) = \underbrace{\int_0^{T_i} P'(t) \frac{v}{\delta} (1 - e^{-\delta t}) dt}_{\text{data breach before } T_i} + \underbrace{[1 - P(T_i)] \left(\frac{v}{\delta} - e^{-\delta T_i} c \right)}_{\text{stay safe until } T_i}. \quad (1)$$

The first term represents the outcome in which the firm's system gets breached before getting protected, which happens with probability $P(T_i)$. The second term represents the more favorable outcome in which the firm's system stays safe until T_i . And if the firm remains safe until T_i , it will incur the investment cost of which the present value is $e^{-\delta T_i} c$. This happens with probability $1 - P(T_i)$.

The optimal timing problem for the firm i is then given by

$$\max_{T_i \geq 0} \mathbb{E}[\pi_i](T_i). \quad (2)$$

The first-order condition for firm i 's optimal timing T_i^* is therefore

$$P'(T_i^*) \frac{v}{\delta} (1 - e^{-\delta T_i^*}) - P'(T_i^*) \left(\frac{v}{\delta} - e^{-\delta T_i^*} c \right) + (1 - P(T_i^*)) \delta e^{-\delta T_i^*} c = 0$$

Increasing the T_i has an economic trade-off: on the one hand, it delays the incidence of the security cost and thus saves $(1 - P(T_i)) \delta e^{-\delta T_i} c$, but increases the likelihood of getting breached thus a profit loss $P'(T_i) \left(\frac{v}{\delta} - c \right)$. Rearranging the equation, we obtain a threshold condition for firm i to invest in security:

$$\underbrace{H(T_i^*) \equiv \frac{P'(T_i^*)}{1 - P(T_i^*)}}_{\text{hazard rate of a data breach}} = \frac{\delta^2 c}{v - \delta c} \text{ for } i. \quad (3)$$

The left-hand side of (3) is the hazard function associated with the likelihood of a data breach $P(T_i^*)$. It is the probability of a breach at exactly time T_i^* conditional on not having been breached until time T_i^* . We know that $P(t)$ is increasing in t , but $P'(t)$ can be either rising or falling with t . Suppose the hazard function $H(t)$ is also increasing; then, when the threshold condition is met, all firms will invest. This is the same observation that has been made in [Francis \(1997\)](#) in the context of vaccine market.

The threshold depends on three parameters v , δ , and c . The firm will get protected sooner if it values the system more (an increase of v), or it pays a lower security cost (a decrease of c), or it

is less patient (a decrease of δ).⁷

The key function in the security decision problem is the *hazard rate* $H(t)$. $H(t)$ is important in at least two aspects. First, $H(t)$ determines whether security adoption is independent or interdependent. The adoption decision is interdependent if the hazard function for firm i depends on when firm j gets protection. If firm j does not invest and gets breached prior to T_i , with all other things equal, the hazard rate for i will go up and firm i is more likely to get breached as well. This is the externality problem: every individual firm does not bear the full consequence of its own security decision. Second, $H(t)$ dictates the equilibrium behavior of firms' adoption. As noted above, an increasing hazard rate will lead to a "tipping point" threshold rule. In what follows, we will show that the market dynamics lead to a hazard rate $H(t)$ that is both increasing and interdependent.

3.1 Market Equilibrium

A firm's system can get breached in two ways. One is the direct attack of hackers, and the other is the indirect contagion of the infected computers that are brought under the control of the hackers. The second way is often referred to as the "botnet": a network of thousands or even millions of infected computers called "bots" that is used by the hackers to carry out a wide range of cyber attacks. The attacks include sending spam, phishing, identity theft, click fraud, launching denial-of-service attacks, and distribution of adware and other malicious programs.

It is perhaps intuitive to think of the propagation of infected computers as an epidemic caused by biological virus.⁸ In fact, it is customary in the literature to formulate the botnet dynamics as the SI (Susceptible - Infectious) model classical in mathematical biology and network science.⁹ In the classical SI model, susceptible individuals in a population interact with one

⁷First, note that if either the discount factor δ or the cost c is zero, then the firm will prefer to get protected regardless of how small the proportion of infected computers are present in the population. Suppose $\delta = 0$ such that the future profit is given the same weight as present profit, this implies that the loss associated with getting infected has an unbounded present value. Given that the cost of security is finite, the firm always prefers to invest in security beforehand. Similarly if $c = 0$ such that security is costless, it would also be preferable to adopt security to prevent a positive expected loss. Lastly, if $v \leq \delta c$ such that the denominator of the threshold is negative, the firm would never choose to get protected regardless of the hazard rate. This is because the breached data is worth so little to the firm that it cannot justify the cost of securing it.

⁸This analogy would hold for conventional worms for which the attackers use Pure Random Scan to identify vulnerable computers. Usually under the Random Scans, every infected computer constantly performs a fixed number of scans on other computers per unit of time. See [Yu et al. \(2009\)](#) for a discussion of self-disciplinary worms that behave differently than conventional worms.

⁹Empirical studies have shown that when N is large, the deterministic epidemic models can successfully represent the dynamics of the malware propagation (see [Khouzani et al. \(2011\)](#) and the references therein). For a general reference

another and are exposed to an infectious disease. Once infected, the individual shifts from the susceptible to the infected state. Upon infection, the individual remains infectious thereafter. In what follows, I build upon the SI model to capture the market dynamics of information security. A graphical illustration is shown in Figure 1.

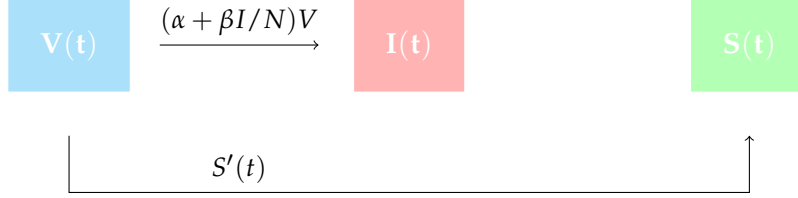


Figure 1: A Graphical Illustration of the Market Dynamics

Define $V(t)$, $I(t)$, and $S(t)$ as the number of vulnerable, infected, and secured firms respectively, at time t that exhaustively and mutually exclusively categorize a population of size $N \gg 0$. Instantaneously, there is a probability $\alpha > 0$ of a direct attack that breaches a firm's system and turns it into a bot, and a probability $\beta > 0$ of a malicious connection between a vulnerable firm and an infectious firm, conditional on not being directly attacked. Since $I(t)/N$ is the fraction of infectious firms at time t and also the chance of an encounter with a bot, the probability of a vulnerable firm getting breached at time t is $\alpha + \beta I(t)/N$.

We introduce security investment in such a way that if vulnerable firms invest in protection, they will never become breached.¹⁰ The laws of motion for this market are thus stated as the following nonlinear differential equations:

$$V'(t) = -\alpha V(t) - \frac{\beta I(t)V(t)}{N} - S'(t) \quad (4)$$

$$I'(t) = \alpha V(t) + \frac{\beta I(t)V(t)}{N} \quad (5)$$

where $S'(t)$ is the incremental change of secured firms in the population, or the rate of security adoption. Equation (4) specifies the rate of change in the number of vulnerable firms as a result of direct attack, indirect attack, and security investment. Equation (5) specifies the rate of change in data breach incidents as a result of botnet growth. Also note that for given any t , $V(t) + I(t) + S(t) = N$.¹¹

The equilibrium concept is rational expectation equilibrium. Because of rational expectation, of the SI models and its family, see [Keeling and Rohani \(2008\)](#).

¹⁰We can relax this assumption to allow for imperfect security protection by adding a parameter on the fraction of investors that gets secured.

¹¹We assume that $I(0) = 0$, $S(0)$ is small, and $I'(t) > 0$ for any t .

the firms' beliefs correctly reflect the actual state of the market. Equation (3) is based on firms' beliefs regarding the market, which should correctly anticipate the market dynamics in equation (4) and (5). This is a critical informational assumption in the efficiency result. In Section 8, I relax the public information assumption, which breaks the efficiency result we found in the full information environment.

Note that at time t the number of firms that will get breached is $I'(t)$. Since there $V(t)$ vulnerable and all are at equal risk, the true hazard rate $H(t)$ is $H(t) = \frac{I'(t)}{V(t)} = \alpha + \frac{\beta I(t)}{N}$. By equating the firm's belief to the true hazard at time T_i^* , we get

$$\alpha + \beta \frac{I(T_i^*)}{N} = \frac{\delta^2 c}{v - \delta c}. \quad (6)$$

Thus a firm's decision on when to get protected depends directly on the fraction of the population that has been breached, or in malware context, the botnet size.

We can take a closer look at the hazard rate generated by the market dynamics $H(t) = \alpha + \frac{\beta I(t)}{N}$. $\beta > 0$ is what makes the hazard rate increasing and interdependent. Suppose instead that $\beta = 0$, every firm just has to deal with the direct attacks separately and the adoption decisions are independent. Because of $\beta > 0$, the hazard rate for firm i depends on the decision of other firms $j \neq i$. But also note that the hazard rate $H(t)$ does not depend on $S(t)$ directly but instead through the mediating state variable $I(t)$. We can see this more clearly by rewriting the hazard rate $H(t)$ as a function of the market-level investment rate $S'(t)$, i.e., $H(T_i) = \alpha + \beta[1 - \frac{V(T_i)}{N} - \frac{\int_0^{T_i} S'(t)dt}{N}]$. This distinction is important for the diverging welfare results between this paper and [Lelarge \(2009\)](#), which I will elaborate in Section 7.

For now, let us just note the externalities problem in the market as to how T_j will affect the optimal timing of firm i . Suppose $T_j < T_i$, $S'(t)$ becomes larger, and $I(T_i)$ becomes smaller, which gives firm i less incentive to invest. Suppose instead $T_j > T_i$, $S'(t)$ becomes smaller, and $I(T_i)$ becomes larger, which gives firm i more incentive to invest. Timing of T_j will affect the optimal timing of T_i . This is because of the externalities in security investment.

This dynamic system will be such that, once the threshold size of the botnet has been reached, all remaining vulnerable will immediately get protected. Initially, $I(t)$ is below the threshold level, and no firms invest in security $S'(t) = 0$. The botnet size grows as can be seen in (5) where $I(t)$ never decreases as $I'(t) \geq 0$ for all t . Once the critical mass $I(T^*)$ has been reached, firms will start to prefer getting protected. However, the fact that some firms go and get their

protection will *not remove the incentive* for all the other remaining vulnerable in doing the same (the left-hand side of (6) remains above the threshold). The fact that all will go at exactly the same time is a special feature of the homogeneous model, which has been highlighted in Francis (1997).¹²

This behavior is in line with the network effects of technology adoption as argued by Katz and Shapiro (1985). Initially there is slow or no adoption due to the lower benefit compared to the cost, once a critical mass of firms is reached, much more rapid deployment would be seen, leading to a S-shaped adoption curve. The slow adoption of more secure internet protocols would be an example. This rule also means that introducing cybersecurity to the market can be hard, because below the threshold, investing in security is not incentive compatible. This is consistent with Herley (2009) showing that when the at-risk probability is small, designing security advice that is beneficial is very hard.¹³

3.2 Social Optimality

The planner's problem is to choose the rate of security adoption $r(t)$ to maximize the present value of the unweighted sum of profits of all firms. The problem can be stated as follows:

$$\max_{r(t)} \int_0^\infty e^{-\delta t} [(N - I(t))v - cr(t)] dt \quad (7)$$

$$\text{s.t. } S'(t) = r(t), \quad (8)$$

$$I'(t) = [\alpha + \beta \frac{I(t)}{N}] [N - I(t) - S(t)], \quad (9)$$

$$r(t) \geq 0, \quad (10)$$

$$I(0), S(0) \text{ given.} \quad (11)$$

This is an optimal control problem with adoption rate $r(t)$ as the control variable and $I(t), S(t)$ as the state variables. The Hamiltonian for this problem is

$$H(r, S, I, \lambda, t) = e^{-\delta t} [(N - I(t))v - cr(t)] + \lambda_1(t)r(t) + \lambda_2(t)[\alpha + \beta \frac{I(t)}{N}] [N - I(t) - S(t)] + \lambda_3(t)r(t),$$

¹²Varying parameters and initial conditions may affect the timing of adoption, but do not affect the firm's optimal time-of-adoption rule.

¹³I also consider ex-post recovery in one of the extensions in Section 6.

where $\lambda_1(t), \lambda_2(t), \lambda_3(t)$ are Lagrangian multipliers on the constraints (8), (9), (10), respectively. By the maximum principle, the necessary conditions for an optimal path are

$$\frac{\partial H}{\partial r} = 0 = -e^{-\delta t}c + \lambda_1(t) + \lambda_3(t) \quad (12)$$

$$-\frac{\partial H}{\partial S} = \lambda'_1(t) = -\{-\lambda_2(t)[\alpha + \beta \frac{I(t)}{N}]\} \quad (13)$$

$$-\frac{\partial H}{\partial I} = \lambda'_2(t) = -\{-e^{-\delta t}v + \lambda_2(t)[\frac{\beta}{N}(N - I(t) - S(t)) - (\alpha + \beta \frac{I(t)}{N})]\} \quad (14)$$

together with three constraints (8), (9) and (10).

Suppose the non-negative constraint (10) is binding, then $\lambda_3(t) > 0$ and $r(t) = 0$. If the optimal path contains a positive adoption rate $r(t) > 0$ for some time interval, then (10) will not be binding and $\lambda_3(t) = 0$. It follows from (12) that $\lambda_1(t) = e^{-\delta t}c$. It is therefore the case that $\lambda'_1(t) = -e^{-\delta t}\delta c$. Substitution into (13) gives us $\lambda_2(t) = -e^{-\delta t}\delta c[\alpha + \beta \frac{I(t)}{N}]^{-1}$, which has the time derivative as $\lambda'_2(t) = -\lambda_2(t)[\delta + \frac{\beta I'(t)}{\alpha N + \beta I(t)}]$. Together with (9) and (14), this implies the socially optimal timing T^e is such that

$$\alpha + \beta \frac{I(T^e)}{N} = \frac{\delta^2 c}{v - \delta c}, \quad (15)$$

which is identical to the threshold condition in (6). It follows that $T^e = T^*$ and the two paths are identical.

This optimal control problem has a “bang bang” solution: $r(t)$ is at its minimum level $r(t) = 0$ when $\alpha + \beta \frac{I(t)}{N} < \frac{\delta^2 c}{v - \delta c}$ and $r(t)$ is at its maximum level when $\alpha + \beta \frac{I(t)}{N} \geq \frac{\delta^2 c}{v - \delta c}$. This is expected as the objective function and the Hamiltonian is linear in the control variable $r(t)$. It is noteworthy that in the socially optimal path, data breach is not pushed to zero and certain degree of insecurity would be allowed so long as it is cost justified.

There is another way to solve the social planner’s problem as an optimal stopping problem, given that all the unprotected firms adopt security at the same time. Let T^e be the efficient timing of investment. The social planner’s problem can be restated as an optimal stopping problem analogous to the firm’s problem such that the planner chooses T^e to maximize social welfare:

$$\max_{T^e \geq 0} \int_0^{T^e} e^{-\delta t} [N - I(t)] v dt + [N - I(T^e)] \int_{T^e}^{\infty} e^{-\delta t} v dt - (N - I(T^e) - S(0)) e^{-\delta T^e} c. \quad (16)$$

The first term represents the welfare of the unbreached firms up to time T^e . The second term represents the welfare of the unbreached firms after they make the investment at time T^e . The

third term represents the present discounted value of the total investment costs. The welfare of the breached firms is 0 for any t . Solving the first-order condition of this problem yields exactly the same threshold condition as (15).

In this special homogeneous model, the socially optimal threshold condition (15) is exactly the same as the competitive equilibrium (6). As a result, the competitive equilibrium time path is identical to the socially optimal path. Perhaps surprisingly, externality in security adoption does *not* cause market failure. This is also what Francis (1997) has found in the market of vaccination with no direct attacks.

In the language of Koutsoupas and Papadimitriou (1999), we can calculate the price of anarchy (PoA) in this model. The PoA measures the deterioration in a system's performance in which resources are allocated by self-interested agents. Formally, the PoA is the ratio between the social welfare of the first-best and the social welfare of the non-cooperative market equilibrium. Under the public information assumption, the two are identical in this model (and the later extended models), implying a PoA equal to 1. When public information is sufficient to coordinate the expectation of firms' security decisions, no additional coordination devices is needed.

But this opens up more questions than providing any definite answers. One might think, for instance, it is the homogeneity of firms that drives this result. One might also wonder what happens if investment can be made multiple times or does not confer lifetime protection. In the next section, I show that the market equilibrium path remains socially optimal if we relax these assumptions and study more realistic models of the security industry.

3.3 Externality-based Interventions

Subsidy. Suppose the government provides a subsidy $s > 0$ for security adoption. The cost of adopting security then becomes $c - s$. Firm i 's optimal timing under subsidy T_i^s will follow the threshold condition:

$$H(T_i^s) = \frac{\delta^2(c - s)}{v - \delta(c - s)} < \frac{\delta^2 c}{v - \delta c} = H(T_i^*). \quad (17)$$

Subsidy induces the firms to invest in security too early. The distortion happens regardless of the size of the subsidy.

Mandate. Suppose the government mandate the firms to adopt security at T_i^* . To do that, the government has to know a lot of information on the firms side. Cost c and discounting factor

δ can be reasonably approximated by the market price and the interest rate. But the value v , the vulnerability α and β are much harder to calibrate, especially so when there is heterogeneity. In the likely case when the government mis-calibrate, a mandate may lead to either over-investment or delayed investment. Even though the government manages to get the numbers right, a mandate, in light of the efficiency of the market, is an unnecessary burden on the administration system.

Liability. Suppose the government holds the firms strictly liable for a data breach incident, in which case the infected firm would pay a damage $d > 0$. The instantaneous profit loss of a security breach then becomes $v + d$. Firm i 's optimal timing under legal liability T_i^l will follow the threshold condition:

$$H(T_i^l) = \frac{\delta^2 c}{v + d - \delta c} < \frac{\delta^2 c}{v - \delta c} = H(T_i^*). \quad (18)$$

Once again, the firms will sub-optimally rush to invest in security. The distortion happens regardless of the size of the damages.

For all three externality-based interventions, both the social welfare and the profit of the firms are reduced. Because of the market efficiency, policies would be distortionary. They put unnecessary burden on the firms. For some firms with a high fixed cost, they might be forced to exit the market. By distorting the right incentive to invest and imposing unavoidable administration costs, the interventions cause pure deadweight loss.

4 Heterogeneous Demand and Heterogeneous Vulnerability

In this section, I discuss two heterogeneous models of the security industry and show that the welfare result still holds. The two models show that the welfare theorem does not hinge on the homogeneity assumption.

4.1 General Demand for Security

Plausibly, information system or Internet service might not be equally important to all firms depending on the industry and business model. Firms may thus place different values on information security. The different values can be a result of product market competition (e.g., v is higher for firms with a larger market share) or reputation loss (e.g., v is higher for firms experiencing a sharper drop in stock price). In this subsection, I study an extended model to incorporate hetero-

geneous demand for security.

Suppose there are two types of firms with different valuations: a fraction μ_H of all the firms has a high valuation v_H , and the rest μ_L has a low valuation v_L where $\mu_H + \mu_L = 1$ and $v_H > v_L$.¹⁴ Let $V_i(t)$, $I_i(t)$, and $S_i(t)$ be the number of vulnerable, infected, and secured firms of type $i \in \{L, H\}$ respectively such that $\sum_i V_i(t) + I_i(t) + S_i(t) = N$. The laws of motion become

$$V'_L(t) = -\alpha V_L(t) - \frac{\beta \sum_i I_i(t) V_L(t)}{N} - S'_L(t), \quad (19)$$

$$V'_H(t) = -\alpha V_H(t) - \frac{\beta \sum_i I_i(t) V_H(t)}{N} - S'_H(t), \quad (20)$$

$$I'_L(t) = \alpha V_L(t) + \frac{\beta \sum_i I_i(t) V_L(t)}{N}, \quad (21)$$

$$I'_H(t) = \alpha V_H(t) + \frac{\beta \sum_i I_i(t) V_H(t)}{N} \quad (22)$$

such that for each type i , $V'_i(t) + I'_i(t) + S'_i(t) = 0$. Initial conditions are assumed to be $I_i(0) = S_i(0) = 0$ for $i \in \{L, H\}$. Notice that an infected firm poses the same risk to all remaining vulnerable firms regardless of the type.

The market outcome can be similarly characterized by applying inequality (3). Firms of type i will invest in security at time T_i^* if

$$\alpha + \beta \frac{\sum_i \mu_i I_i(T_i^*)}{N} = \frac{\delta^2 c}{v_i - \delta c}. \quad (23)$$

The above threshold conditions are similar to condition (6) in that the equilibrium timing is dependent on the botnet size $\sum_i I_i(t)$ which preserves the non-decreasing property. The thresholds for the two types are different: since $v_H > v_L$, the threshold for the high type is lower. In the resulting equilibrium, firms will get protected in two phases. For the high valuation group, all the remaining vulnerable firms will invest in security at T_H when the botnet size $I(T_H)$ crosses the threshold. At that time $S(t)$ jumps to $V_H(t)$ and $V_H(t)$ drops to zero. Once that occurs, the situation reverts back to the homogeneous case: all the remaining vulnerable firms are low valuation firms. The low valuation firms who remain vulnerable will invest in security at T_L when the botnet size $I(T_L)$ crosses the higher threshold. At T_L all remaining vulnerable firms get protected and the dynamic system is thereafter in steady state.

The social planner's problem can be solved similarly as in Section 3. The planner chooses

¹⁴The model can be readily extended to more than two types.

T_H^e and T_L^e to maximize social welfare:

$$\max_{T_H \geq 0, T_L \geq 0} \sum_i \int_0^{T_i} e^{-\delta t} V_i(t) v_i dt + \sum_i \int_{T_i}^{\infty} e^{-\delta t} V_i(T_i) v_i dt - \sum_i e^{-\delta T_i} V_i(T_i) c.$$

From first-order conditions, we obtain for $i \in \{L, H\}$,

$$0 = (c - \frac{v_i}{\delta}) I_i'(T_i^e) + \delta c V_i(T_i^e).$$

Together with the law of motion of $I_i'(t)$, we get for $i \in \{L, H\}$, social optimality requires them to invest at T_i^e such that

$$\alpha + \beta \frac{\sum_i I_i(T_i^e)}{N} = \frac{\delta^2 c}{v_i - \delta c}, \quad (24)$$

which extends equation (15) to this heterogeneous valuation case. Comparing the planner's threshold condition (24) with the equilibrium condition (23), we conclude that the market equilibrium path is identical to the socially optimal path.

4.2 Competitive Effects of Security

We can use a variation of the heterogeneous demand model to study the competitive effects of security. Security decisions can also be shaped by competitive forces: firms may benefit and anticipate gaining market shares if less secure competitors are compromised. There are papers showing that security can be leveraged as product differentiation ([Arce, 2020](#); [Sen et al., 2020](#); [De Cornière and Taylor, 2024](#)).

Fully solving the dynamics of market competition and security is beyond the scope of this paper, but our model can accommodate the competitive effects of security in a reduced-form way. Let the instantaneous market value $v(I(t))$ be a continuously differentiable and *increasing* function of the number of infected firms $I(t)$. This captures the fact that as more competitors are crippled by data breaches (i.e., $I(t)$ increases), a surviving firm may gain a higher market share, e.g., by acquiring customers or facing less price competition. This creates an additional incentive to be the “last ones standing” in the market. Firms face a trade-off between competition and security: waiting (conditional on surviving) increases both profits per period and the risk of breach.

The PDV of a firm's profit stream, assuming the system is breached at time t , now becomes $\pi(t) = \int_0^t v(I(\tau)) e^{-\delta \tau} d\tau$. If the firm never gets breached, the PDV of profits is $\hat{\pi} = \lim_{t \rightarrow \infty} \pi(t)$.

Suppose firm i plans to get protected at time T_i , the expected PDV of profits would be

$$\mathbb{E}[\pi_i](T_i) = \int_0^{T_i} P'(t)\pi(t)dt + [1 - P(T_i)](\hat{\pi} - e^{-\delta T_i}c), \quad (25)$$

that naturally extends equation (1). The optimal timing T_i^* follows a threshold condition that extends equation (3):

$$\frac{P'(T_i^*)}{1 - P(T_i^*)} = \frac{\delta^2 c}{\delta e^{\delta T_i^*} [\hat{\pi} - \pi(T_i^*)] - \delta c} = \frac{\delta^2 c}{\Pi(T_i^*) - \delta c} \text{ for } i, \quad (26)$$

where $\Pi(T) := \int_T^\infty v(I(t))\delta e^{-\delta(t-T)}dt$. Note that $\Pi(T)$ is increasing in the adoption time T . To see this, we first note that $\Pi'(T) \geq 0$ is equivalent to $\Pi(T) \geq v(I(T))$, that is, the cumulative future profit is larger than the instantaneous reward. By first-order Taylor expansion, $v(I(t)) = v(I(T)) + v'(I(T))I'(T)t$, and $\Pi(T) = v(I(T)) + \frac{v'(I(T))I'(T)}{\delta}$. It follows that

$$\frac{\Pi(T)}{v(I(T))} = 1 + \frac{v'(I(T))I'(T)}{v(I(T))} \geq 1.$$

The second term is the log-derivative of $v(I(t))$ evaluated at time T , interpreted as the proportional growth rate of the market value, which is weakly positive for all t .

The dynamic system behaves similarly to the main model such that once the critical mass of breaches $I(T^*)$ has been reached, all remaining vulnerable will get protected. This happens because the LHS of the threshold condition (25) increases with $I(t)$ (as in the homogeneous model) and the RHS decreases with $I(t)$ (as shown in the property of $\Pi(T)$).

4.3 Weak Targets

Existing economic models of information security highlight the case of the weak targets where a fraction of firms are more likely to be victimized (Varian, 2004; Grossklags et al., 2008; Bohme and Moore, 2010). Empirical supports are available to show that firms of incompetent security practices have been attacked more frequently, as in the payment card industry (Murdoch et al., 2010), the phishing sites (Moore and Clayton, 2009), and the personal computer market (Camp and Wolfram, 2004). In this subsection, I study an extended model to incorporate differences in vulnerability.

Consider two types of firms with different vulnerabilities: a group of highly vulnerable firms

$\mu_H N$ has a high probability of being attacked (α_H, β_H) , and the rest $\mu_L H$ has a low probability of being attacked (α_L, β_L) where $\mu_H + \mu_L = 1$, $\alpha_L \leq \alpha_H$, and $\beta_L \leq \beta_H$.¹⁵ The laws of motion are as follows:

$$V'_L(t) = -\alpha_L V_L(t) - \frac{\beta_L \sum_i I_i(t) V_L(t)}{N} - S'_L(t), \quad (27)$$

$$V'_H(t) = -\alpha_H V_H(t) - \frac{\beta_H \sum_i I_i(t) V_H(t)}{N} - S'_H(t), \quad (28)$$

$$I'_L(t) = \alpha_L V_L(t) + \frac{\beta_L \sum_i I_i(t) V_L(t)}{N}, \quad (29)$$

$$I'_H(t) = \alpha_H V_H(t) + \frac{\beta_H \sum_i I_i(t) V_H(t)}{N}. \quad (30)$$

High-risk firms will invest in security at time T_H^* if

$$\alpha_H + \beta_H \frac{\sum_i I_i(T_H^*)}{N} = \frac{\delta^2 c}{v - \delta c}. \quad (31)$$

Low-risk firms will invest in security at time T_L^* if

$$\alpha_L + \beta_L \frac{\sum_i I_i(T_L^*)}{N} = \frac{\delta^2 c}{v - \delta c}. \quad (32)$$

Since $\alpha_L \leq \alpha_H$ and $\beta_L \leq \beta_H$, the threshold for weak targets is higher than that for strong targets. The resulting market equilibrium is such that the weak targets will take precautions earlier than the strong targets. Weak targets invest at time T_H^* , after which all the remaining vulnerable firms invest at time T_L^* .

The social planner chooses T_H^e, T_L^e to maximize social welfare:

$$\max_{T_H \geq 0, T_L \geq 0} \sum_i \int_0^{T_i} e^{-\delta t} V_i(t) v_i dt + \sum_i \int_{T_i}^{\infty} e^{-\delta t} V_i(T_i) v_i dt - \sum_i e^{-\delta T_i} V_i(T_i) c.$$

From first-order conditions, we obtain for $i \in \{L, H\}$,

$$0 = (c - \frac{v}{\delta}) I'_i(T_i^e) + \delta c V_i(T_i^e).$$

Together with the law of motion of $I'_i(t)$, we get for $i \in \{L, H\}$, social optimality requires them to invest at T_i^e such that

$$\alpha_i + \beta_i \frac{\sum_i I_i(T_i^e)}{N} = \frac{\delta^2 c}{v - \delta c}. \quad (33)$$

¹⁵The model can be readily extended to more than two types.

Comparing the planner's threshold condition with the equilibrium condition, we conclude that the market equilibrium path is identical to the socially optimal path.

5 Various Ways of Security Investment

In this section, I discuss two richer models of security investment and show that the welfare result still holds. The two models show that the efficiency result does not hinge on the way the security investment has been modeled.

5.1 In-House Security Team

Some firms might rely on their in-house security team. Other firms might buy vulnerability from the market, or outsource system defense to third-party vendors ([Sivagnanam et al., 2021](#)). In this subsection, I study an extended model to incorporate self-selection into internal and external security investment.

There are two ways that a firm can get security protection. The first method is to purchase it at the competitive market price c . The second method is to invest in an in-house security team that hires dedicated personnel to discover and fix the bugs. Firms differ in terms of their skill levels, and we can index every firm by their internal security cost s where s is uniformly distributed on $[0, 1]$. Firm s will choose in-house security team if and only if $s \leq c$. For firms with internal security cost higher than c , they will outsource it to the market.

The law of motion would be similar to the equations (19). For firms with $s \leq c$, they will invest in internal security team at time T_s^* if

$$\alpha + \beta \frac{\int_s I_s(T_s^*) ds}{N} = \frac{\delta^2 s}{v - \delta s}. \quad (34)$$

For firms with $s > c$, they will make external security investment at time T_c^* if

$$\alpha + \beta \frac{\int_s I_s(T_c^*) ds}{N} = \frac{\delta^2 c}{v - \delta c}. \quad (35)$$

Every internal investment has a different threshold depending upon s , whereas all the external investment have a same threshold. Because of the self-selection, the thresholds for every firm that

invests in-house is lower than that for the firms that outsource. The resulting market equilibrium is such that the outsourcing firms get protected later than the in-house firms. The in-house firm s will invest in security consecutively at their respective T_s^* . After that, all the remaining vulnerable firms will invest externally at T_c^* and the system is in steady state thereafter.

The social planner chooses T_c^e for outsourcing firms and T_s^e for in-house firms to maximize social welfare:

$$\begin{aligned} \max_{T_s \geq 0, T_c \geq 0} & \int_0^c \int_0^{T_s} e^{-\delta t} V_s(t) v dt ds + \int_0^c \int_{T_s}^{\infty} e^{-\delta t} V_s(T_s) v dt ds - \int_0^c e^{-\delta T_s} V_s(T_s) p ds \\ & + (1-c) \int_0^{T_c} e^{-\delta t} V_s(t) v dt + (1-c) \int_{T_c}^{\infty} e^{-\delta t} V_s(T_c) v dt - (1-c) e^{-\delta T_c} V_s(T_c) c, \end{aligned}$$

where the three terms on the first line are the welfare of the in-house firms and the three terms on the second line are the welfare of the outsourcing firms. Combining the first-order conditions with the law of motion, we have

$$\alpha + \beta \frac{\int_s I_s(T_s^e) ds}{N} = \frac{\delta^2 s}{v - \delta s} \text{ for all } s \leq c, \quad (36)$$

$$\alpha + \beta \frac{\int_s I_s(T_c^e) ds}{N} = \frac{\delta^2 c}{v - \delta c} \text{ for all } s > c. \quad (37)$$

The threshold condition (36) extends equation (15) to take into account the self-selection of firms into internal and external security markets. Comparing it with the equilibrium condition, we conclude that the market equilibrium path is identical to the socially optimal path.

5.2 Security Upgrade

The initial security investment may not confer permanent protection, and investment can be made over time to improve the security features (e.g., Windows). In this subsection, I study an extended model to incorporate the intensive margin of security investment.

Every firm has two opportunities to invest in security, and both would cost c . The first shot protects the firm imperfectly; it reduces the probability of getting breached from (α_H, β_H) to (α_L, β_L) . Every firm can make the second investment to upgrade the security, and the second shot reduces the probability of breach to zero. The firm can make the two investments at the same time or consecutively.

The new technology divides the population into four compartments, where $V(t)$ is the number vulnerable firms, $I(t)$ is the number of infected firms, $S_1(t)$ is the number of firms who invest in security once, and $S_2(t)$ is the number of firms who invest in security twice. The laws of motion are as follows:

$$V'(t) = -\alpha_H V(t) - \frac{\beta_H I(t)V(t)}{N} - r(t), \quad (38)$$

$$S_1'(t) = r(t) - \alpha_L S_1(t) - \frac{\beta_L I(t)S_1(t)}{N} - S_2'(t), \quad (39)$$

$$I'(t) = \alpha_H V(t) + \frac{\beta_H I(t)V(t)}{N} + \alpha_L S_1(t) + \frac{\beta_L I(t)S_1(t)}{N} \quad (40)$$

where $r(t)$ is the rate of first-time security investment and $S_2'(t)$ is the rate of second-time investment. There are two changes to the dynamic system in the homogeneous model ((4) and (5)). First, the changes of uninfected firms are now described by two equations, with the rate of change in $S_1(t)$ added. Second, the growth in botnet size is now due to the infection of both vulnerable firms and firms who have made first-time investment.

Denote $P_1(t)$ and $P_2(t)$ as the cumulative probability distribution of getting breached at or before time t for $V(t)$ and $S_1(t)$ respectively. Suppose the firm plans to install at time T_1 and upgrade at time T_2 , the present discounted value of the expected profits would be

$$\mathbb{E}[u_i](T_1, T_2) = \int_0^{T_1} P_1'(t) \frac{v}{\delta} (1 - e^{-\delta t}) dt + [1 - P_1(T_1)](\mathbb{E}[u_i|T_1](T_2) - e^{-\delta T_1} c), \quad (41)$$

where

$$\mathbb{E}[u_i|T_1](T_2) = \int_{T_1}^{T_2} P_2'(t) \frac{v}{\delta} (1 - e^{-\delta t}) dt + [1 - P_2(T_2)](\frac{v}{\delta} - e^{-\delta T_2} c). \quad (42)$$

Compared with equation (1), we notice that the expected profits of making the initial investment substitute $\frac{v}{\delta}$ with $\mathbb{E}[u_i|T_1](T_2)$. The difference stems from the fact that in the homogeneous model investment confer lifetime protection, whereas in this extension there is the remaining risk after the initial investment and forward looking firms anticipate that. The expected profits of upgrading security given T_1 is the same as (1). This optimization problem has a Markov property: when the firms make the upgrade decision after T_1 , it is *as if* they are choosing the timing of the investment as the homogeneous model assuming T_1 is the start of time. Solving the first-order condition of T_1^* , we have

$$\frac{P_1'(T_1^*)}{1 - P_1(T_1^*)} = \frac{\delta c}{\mathbb{E}[u_i|T_1^*](T_2^*) - c}. \quad (43)$$

Equating the expected hazard rate with the actual hazard rate from (38), we find that firms will

make the initial investment at time T_1^* if

$$\alpha_H + \beta_H \frac{I(T_1^*)}{N} = \frac{\delta c}{\mathbb{E}[u_i|T_1^*](T_2^*) - c}. \quad (44)$$

Solving the first-order condition of T_2^* , we obtain

$$\frac{P_2'(T_2^*)}{1 - P_2(T_2^*)} = \frac{\delta^2 c}{v - \delta c}. \quad (45)$$

Similarly, by rational expectation, the firms will upgrade the security endowment at time T_2^* if

$$\alpha_L + \beta_L \frac{I(T_2^*)}{N} = \frac{\delta^2 c}{v - \delta c}. \quad (46)$$

The social planner chooses T_1^e and T_2^e to maximize social welfare:

$$\max_{T_1 \geq 0, T_2 \geq 0} \int_0^{T_1} e^{-\delta t} V(t) v dt - V(T_1) e^{-\delta T_1} c + [N - I(T_1)] TS(T_2|T_1), \quad (47)$$

where the firms' total surplus of $S_1(t)$ given they invest at T_1 is written as

$$TS(T_2|T_1) = \int_{T_1}^{T_2} e^{-\delta t} S_1(t) v dt + S_1(T_2) \int_{T_2}^{\infty} e^{-\delta t} v dt - S_1(T_2) e^{-\delta T_2} c. \quad (48)$$

Combing the first-order condition of T_1^e and T_2^e with the laws of motion, we have

$$\alpha_H + \beta_H \frac{I(T_1^e)}{N} = \frac{\delta c}{TS(T_2^e|T_1^e) - c}, \quad (49)$$

$$\alpha_L + \beta_L \frac{I(T_2^e)}{N} = \frac{\delta^2 c}{v - \delta c}. \quad (50)$$

It turns out that $TS(T_2|T_1) = \mathbb{E}[u_i|T_1](T_2)$. This is not surprising given the Markov property of the problem: starting from T_1 , the equilibrium path and the social optimal path are just like what we have solved in section 3. Consequently, the planner's two threshold conditions coincide with the equilibrium threshold conditions. The market equilibrium path is identical to the socially optimal path. ¹⁶

¹⁶Another extension along this line is the dynamic pricing of security products. In the paper, security products are provided at a fixed market price c . In general, one can allow the price to vary across periods $c(t)$. If $c(t)$ is weakly decreasing over time, the efficiency results would hold. If $c(t)$ is increasing, then it would depend on the rate of change.

6 Ex-ante Precaution and Ex-post Recovery

In all of the above models, we assume that once a computer is infected, it will remain infected thereafter. However, there are instances where firms can get out of infection after a cyber attack. For example, firms may pay ransom to get their data restored; they may also employ technicians to repair infected devices. In this subsection, I study an extended model to incorporate the recovery from infection ex-post.

Let γ be the probability that a firm may recover from infection and become vulnerable again. The basic setup follows the homogeneous model, except that the laws of motion become

$$\begin{aligned} V'(t) &= -\alpha V(t) - \frac{\beta I(t)V(t)}{N} + \gamma I(t) - S'(t) \\ I'(t) &= \alpha V(t) + \frac{\beta I(t)V(t)}{N} - \gamma I(t), \end{aligned}$$

such that the rate of change in data breach incidents is the net flow of direct and indirect attack minus the rate of recovery. Unlike the homogeneous model, the number of vulnerable firms might rebound. The hazard rate is $\lambda(t) = \frac{I'(t)}{V(t)} = \alpha + \beta \frac{I(t)}{N} - \gamma \frac{I(t)}{V(t)}$. A firm will invest in security at time T_i^* if

$$\alpha + \beta \frac{I(T_i^*)}{N} - \gamma \frac{I(T_i^*)}{V(T_i^*)} = \frac{\delta^2 c}{v - \delta c}. \quad (51)$$

This threshold condition differs from (6) in that it now involves $V(t)$. Once the condition is met, firms will prefer getting protected and $S(t)$ goes up. Two countervailing forces exist on the changes of $V(t)$. The increase in $S(t)$ leads to a decrease of $V(t)$, which would provide a disincentive for other firms to invest. On the other hand, simultaneous recovery leads to an increase of $V(t)$ and will bound $V(t)$ from below. Unlike the homogeneous model, $I(t)$ is no longer an absorbing state and we denote $\hat{V}$ as the steady state number of vulnerable.

Whether the ex-post recovery will crowd out the incentive for ex-ante precaution depends on the value of γ . If $\gamma \leq \frac{\beta \hat{V}}{N}, \frac{\beta}{N} - \frac{\gamma}{V(t)} \geq 0$ for all t , and the increasing hazard rate condition holds for (51). Akin to the homogeneous model, the fact that some firms get protection does not remove the incentive for the rest in doing the same. The market equilibrium is such that all the remaining vulnerable firms will invest at time T^* . If instead $\gamma > \frac{\beta \hat{V}}{N}$, the increasing hazard rate condition will be violated, and the optimal timing might be delayed.

The social planner's problem is the same as (16). Combining the first-order condition and

the law of motion of $I'(t)$, we obtain the socially optimal T^e such that

$$\alpha + \beta \frac{I(T^e)}{N} - \gamma \frac{I(T^e)}{V(T^e)} = \frac{\delta^2 c}{v - \delta c}. \quad (52)$$

Comparing the threshold condition (52) with the equilibrium condition (51), we conclude that the market equilibrium path is identical to the socially optimal path if the rate of recovery is bounded above (i.e., $\gamma \leq \frac{\beta \hat{V}}{N}$). For large γ , market equilibrium path has inefficient delay. The delay is intuitive: if every firm will quickly recover from the cyber attack, why bother to invest in protection in the first place? But to me, the dependence on γ in this model is not a refutation of the theory for two reasons. First, the value of γ is an empirical question and in many instances given the increasing complexity of attacks, γ is plausibly low. Second, market adoption can remain efficient for a range of γ in this model. By contrast, when information becomes private, as in Section 8, under *no* restrictions on the parameters, the investment timing can be efficient.

7 Intuition and Lindahl Equilibrium

We have seen that the series of models presented so far, there is no divergence between the market outcome and the first-best outcome even in the presence of externalities. There is no “price” of anarchy. Why is this so? In what follows, I provide my intuition for the market efficiency results and also comment on how the results can be tied to the literature on externalities and public good provision.

A classical result in the market provision of public good is the under-provision resulted from free-riding behavior. In our model, cybersecurity $S(t)$ can be viewed as a public good but market results in efficient provision. What explains this discrepancy? In subsection 7.1, I compare my models with [Lelarge \(2009\)](#) to explain the diverging welfare results.¹⁷ What happens in the static model is that the probability of a data breach for one single firm is assumed as a function of the joint efforts of all firms (i.e., $P(t)$ is a function of $S(t)$), making the security investment strategic substitute (which also violates the increasing hazard rate condition of the dynamic model). In our dynamic model, investment is *not* strategic substitute. The threshold rule (6) does not depend on the number of secure firms $S(t)$ but does depend on the number of breach incidents $I(t)$. When the firm decides whether to invest or not, it does not care *directly* about whether others are getting

¹⁷The insights from the comparison can carry over to the static models of [Varian \(2004\)](#) and [Kunreuther and Heal \(2003\)](#), in which the principle of under-provision applies.

protected or not. The fact that other firms might get their protection will not remove the private incentive to get protected.

I will argue that $P(t)$ as a function of $I(t)$ rather than $S(t)$ is a natural consequence of the dynamic perspective. The process of $S(t)$ affecting $P(t)$ is through the *mediating variable* of $I(t)$. Viewing in this vein, there are two dynamic externalities associated with security decisions. The first one is the positive externality highlighted in the static models. Security investment reduces the likelihood that unprotected firms will be infected and thus create positive externality to other firms. Following this logic, the equilibrium investment in my models shall be instead lagged than the efficient investment. However, there is also the negative externality. Not investing today $S'(t) = 0$ increases the likelihood that all vulnerable firms will be infected tomorrow $\alpha + \beta I(t + \Delta)/N$, which in turn increases the likelihood that this firm itself will be infected in the future. This negative externality imposed by the growth of the botnet forces the firms to invest sooner, and as such internalize the external effects of security investment.

Now we can understand the market efficiency results from a marginal analysis perspective. Social optimality equates marginal social benefit with marginal social cost, whereas firms in the market equates marginal private benefit with marginal private cost. In both problems, the marginal cost is the present discounted value of c . The two sources of externalities provide countervailing forces on the marginal private benefit. Because the firms internalize the external effects of security investment, the equilibrium path coincides with the socially optimal path. ¹⁸

The idea that externalities do not necessarily lead to market failure is not novel. The Coase theorem famously states that if trade of the externality can occur, the decentralized bargaining will lead to an efficient outcome (Coase, 1960). Meade (1952) made the first observation, which was later substantially extended by Arrow (1969), that the inefficiency caused by externalities can be seen as the absence of certain competitive markets. Once a market exists for an externality, each consumer decides for herself how much of the externality to consume at the ongoing prices. Viewing in this vein, the presence of externality does not necessarily call for government interventions but instead call for the creation or the reinstatement of new markets. In our model, the security cost c is a price of the breach externality. More precisely, there is an infinite sequence of spot markets available for security investment where security is priced at $e^{-\delta t}c$ for all t . The unfolding of time solves the missing market problem in this model. In fact, the market equilibrium path looks

¹⁸The distinction between these two sources of externalities has also been noted in the economics literature on epidemic control. The positive externality is called the prevention externality, and the negative externality is called the infection externality. See Gersovitz and Hammer (2004) for a reference.

a lot like a Lindahl equilibrium (Lindahl, 1958). In our model, $e^{-\delta(T_i - T_i^*)}c$ are the Lindal prices for cybersecurity, allowing firms to self-select into their personalized markets based on their profitability, perceived risk, etc. In subsection 7.2, I interpret the efficient equilibrium in my models as a Lindahl equilibrium.

7.1 Comparison with Lelarge (2009)

Lelarge (2009) also studies security adoption in an epidemic modeling framework. He finds that equilibrium adoption is inefficient because of a free-riding problem. In what follows, I recast his model in our notations and point to the differences that lead to the diverging welfare results.

Lelarge (2009)'s analysis is based on three key parameters: the cost of protection, the loss of a breach, and the probability of loss. Self-protection costs c . Each agent can decide whether to invest in self-protection and deploy security solutions that reduce the probability of a loss. The agent is in state S if she invests or in state V if she does not invest. The loss of a breach is the difference in payoffs between the two states, which is v in our model. The probability of loss is p^V in state V and p^S in state S . In our model, $p^S = 0$ and only p^V remains. And because Lelarge (2009) is a one-period game, we can think of $p^V = P'(t)$ in the steady state. As in my models, p^V consists of two components: there is probability α of direct attack and probability β of indirect contagion from an infectious connection. Different from my models, however, the breach probability $p^V(S/N)$ is assumed to depend *directly* on the fraction of secured firms $\frac{S}{N}$. He wrote "More precisely, for a fixed fraction of the population $\frac{S}{N}$ investing in security, we define $p^V(S/N)$ and $p^S(S/N)$ as the corresponding probabilities of loss averaged over the population, conditionally on the decision to invest in self-protection."

The optimal strategy of an agent follows a threshold rule $p^V(S/N)v > c$. Assuming loss v_i is heterogeneous across the agents, all agents with $v_i > \frac{c}{p^V(S/N)}$ will invest in self-protection. In a rational expectation equilibrium, the equilibrium size of the network is self-fulfilling and equilibrium security S^* is characterized by the fixed-point equation

$$\frac{S^*}{N} = 1 - F\left(\frac{c}{p^V(S^*/N)}\right). \quad (53)$$

We can evaluate social welfare by $W(S) = [p^V(0) - p^V(S/N)] \int_{S/N}^1 F^{-1}(1-u)du + p^V(0) \int_0^{S/N} F^{-1}(1-u)du - cS/N$, where the first term is the total payoffs of the fraction of agents

in state V , the second and third term are the total payoffs of the agents in state S . We can now compare the equilibrium adoption S^* with the efficient adoption S^e . [Lelarge \(2009\)](#)'s Theorem 1 states that the equilibrium adoption in his security game is inefficiently low, i.e., $S^* < S^e$, or $W'(S^*) > W'(S^e) = 0$. The inefficiency comes from a free-riding problem. As the fraction of agents investing in self-protection S increases, the incentive for the vulnerable to invest decreases. "As more agents invest, the expected benefit of following suit decreases since there is a lower probability of loss." This happens because the breach probability function $p^V(S/N)$ is assumed inversely related to S , which (i) makes the agents' adoption decisions strategic substitute, and (ii) violates the increasing hazard rate condition in my models. ¹⁹

7.2 A Lindahl Equilibrium Interpretation

In a Lindahl equilibrium, every contributor gets their personalized price for the public good. Each contributor, taking the price in the personalized market as given, fully determines their own level of consumption of the public good. A Lindahl equilibrium is Pareto optimal because the price menu allows the contributors to align with the marginal social benefit. As a result, externalities are eliminated.

We can recast our model as a game of public good contribution, in which early adoption would mean more contribution and higher spillovers to the other agents. Formally, a profile of adoption timing $\{T_i^*\}_{i=1}^N$ is a Lindahl equilibrium if there exists a menu of personalized prices $\{p_i^*\}_{i=1}^N$ such that (i) for all i , T_i^* solve firm i 's profit maximization problem given p_i^* , and (ii) At T_i^* , $p_i^* = c$ (i.e., marginal social benefit equal to marginal cost).

In this model, the Lindahl prices for cybersecurity adoption would be $p_i^*(T_i) = e^{-\delta(T_i - T_i^*)}c$. It is straightforward to check that given the stated price menu, $\{T_i^*\}_{i=1}^N$ is a Lindahl equilibrium. First, at exactly T_i^* , we have $p_i^* = e^{-\delta(T_i^* - T_i^*)}c = c$, satisfying condition (ii). Second, T_i^* is the profit maximizer as shown in (6). The Lindahl price is also the social value of security adoption and can be obtained if we differentiate the social welfare function (16) with respect to $V(t)$.

¹⁹I will not argue which model is the "right" model but simply note that [Lelarge \(2009\)](#) recognizes the importance of the dynamics and the information assumption too, for which he wrote "Our epidemic risks model is a simple one-period game and agents have no possibility of learning of value (of S/N)", and "Clearly, the decision made by the agent depends on the information available to her and modelling the information sharing among the agents is an intricate question."

8 When Would the Efficiency Results Break Down? Information Asymmetry

Behind the scenes of the analysis so far, I maintain a fundamental assumption regarding firms' decision-making - the information assumption. Firms are fully informed about the data breach risk in the population over time $I(t)$. This may not be true in reality. Firms are oftentimes asymmetrically informed. In fact, the US Cybersecurity Information Sharing Act and various states' data breach disclosure laws are getting exactly at that, by mandating the disclosure and communication of data breach incidents.

In this section, I relax the loaded information assumption. We introduce information asymmetry in vulnerability which would eventually break the efficiency result. Information asymmetry in other characteristics can be similarly introduced, which will lead to similar inefficiency outcomes. For illustration purposes, suppose $N = 2$. The vulnerability of each firm α_i can be one of two types $\{\alpha_L, \alpha_H\}$ and is privately observed by firm i . Types follow independent distribution $(\mu, 1 - \mu)$. The solution concept would be Perfect Bayesian equilibrium. Each firm's strategy is a pair (T_H, T_L) . It is straightforward to show that $T_H < T_L$.

In this game, each firm will be uncertain about the trajectory of $I(t)$. From i 's perspective, there are two possible trajectories: $\underline{P}(t)$ and $\bar{P}(t)$. $\underline{P}(t)$ is the CDF of getting breached at or before time t when j is not infected (the "low-risk trajectory"), $\bar{P}(t)$ is the CDF of getting breached at or before time t when j is infected (the "high-risk trajectory"), and $\bar{P}(t) > \underline{P}(t)$ for all t . In equilibrium, they will form rational expectations, which critically depend on who adopts security first. The security risk of firm i depends on the timing of adoption. If firm i adopts security earlier than firm j , then with probability $1 - \underline{P}(t)$, j is not infected and the probability for i to get breached at time t is $\underline{P}'(t)$. With probability $\underline{P}(t)$, j is infected and the probability for i to get breached at time t is $\bar{P}'(t)$. Thus, the expected probability of getting breached at time t is

$$\hat{P}'(t) = \underline{P}'(t)[1 - \underline{P}(t)] + \bar{P}'(t)\underline{P}(t), \quad (54)$$

and $\hat{P}(t)$ is the corresponding cumulative probability distribution. If firm i adopts security later than firm j , then the risk depends on the exact timing of T_j . From $t = 0$ to T_j , the probability of getting breached at time t is $\hat{P}'(t)$. From T_j to T_i , the probability of getting breached at time t is

$\underline{P}'(t)$. Putting things together,

$$\mathbb{E}[\pi_i](T_i) = \Pr(T_j \geq T_i) \mathbb{E}[\pi_i](T_i; \hat{P}(t)) + \Pr(T_j < T_i) \{ \mathbb{E}[\pi_i](T_j; \hat{P}(t)) + \mathbb{E}[\pi_i](T_i - T_j; \underline{P}(t)) \}, \quad (55)$$

where $\mathbb{E}[\pi_i](T_i; \hat{P}(t)) = \int_0^{T_i} \hat{P}'(t) \frac{v}{\delta} (1 - e^{-\delta t}) dt + [1 - \hat{P}(T_i)] (\frac{v}{\delta} - e^{-\delta T_i} c)$ is the expected profit if the other firm adopts security after firm i , and $\mathbb{E}[\pi_i](T_i - T_j; \underline{P}(t)) = \int_{T_j}^{T_i} \underline{P}'(t) \frac{v}{\delta} (1 - e^{-\delta t}) dt + [1 - \underline{P}(T_i)] (\frac{v}{\delta} - e^{-\delta T_i} c)$ is the expected profit during the time between the two adoption decisions if the other firm adopts first.

Suppose firm i is a high vulnerability type α_H , then $\Pr(T_j \geq T_i) = \Pr(\alpha_j \leq \alpha_H) = 1$. The optimality condition can be written as

$$\underline{H}(T_H)[1 - \underline{P}(T_H)] + \bar{H}(T_H)\underline{P}(T_H) = \frac{\delta^2 c}{v - \delta c}, \quad (56)$$

where $\underline{H}(t)$ and $\bar{H}(t)$ are the hazard rates associated with $\underline{P}(t)$ and $\bar{P}(t)$. Since $\underline{H}(t) = \alpha_H$ and $\bar{H}(t) = \alpha_H + \beta/2$, we have the optimal timing for the high vulnerability type:

$$\alpha_H + \frac{\beta \underline{P}(T_H)}{2} = \frac{\delta^2 c}{v - \delta c}. \quad (57)$$

Note that in the complete information benchmark of heterogeneous vulnerability (e.g., (33)), at time T_H , the botnet size is $I(T_H) = 1$, and the left-hand side is $\alpha_L + \frac{\beta}{2} > \alpha_L + \frac{\beta \underline{P}(T_L)}{2}$. It follows that under private information, T_H is larger than the complete information T_H . This happens because the firm i does not observe when firm j has been breached by the time of i 's adoption T_H and, therefore, has uncertainty regarding the realized trajectory (even though firm i rationally anticipate that the other firm will self-protect no sooner than itself). If breach disclosure law is in place, then $\underline{P}(T_H)$ would be substituted by 1, and the optimal timing for α_H would be efficient.

Suppose instead firm i is a low vulnerability type α_L , then $\Pr(T_j \geq T_i) = \Pr(\alpha_j \leq \alpha_L) = \Pr(\alpha_L) = \mu$ and $\Pr(T_j < T_i) = \Pr(\alpha_H) = 1 - \mu$. The first-order condition is

$$\mu \{ \underline{H}(T_L)[1 - \underline{P}(T_L)] + \bar{H}(T_L)\underline{P}(T_L) \} + (1 - \mu)\underline{H}(T_L) = \frac{\delta^2 c}{v - \delta c}. \quad (58)$$

Substituting $\underline{H}(T_L)$ and $\bar{H}(T_L)$, we have the optimal timing for the low vulnerability type:

$$\alpha_L + \mu \frac{\beta \underline{P}(T_L)}{2} = \frac{\delta^2 c}{v - \delta c}. \quad (59)$$

Comparing with the complete information benchmark (33), we obtain that under private information, T_L is larger than its complete information counterpart. The low vulnerability type α_L will delay even further than the high type α_H . Type α_H knows for sure that the other firm will self-protect no sooner than itself. Type α_L , however, has uncertainty over both the other firm's breach and the other firm's adoption timing. With probability $1 - \mu$, the other firm will adopt first and not get infected, which reinforces the low type's free-riding incentive.

Information asymmetry leads to rational delays in security investment. The game is similar to the war of attrition game of Alesina and Drazen (1991) in explaining delays in fiscal stabilization. Both parties want the other to incur the cost first, and they would wait for an overly long period, even though it would be a Pareto improvement for them to coordinate on the timing. This happens because cybersecurity is an interdependent risk (Kunreuther and Heal, 2003). If security decisions are independent, the market equilibrium would remain ex-ante efficient, as the firms has no need to know the other party's timing of adoption or breach.

Since the inefficiency is in the form of delays, public subsidy or liability would get the firms closer to socially efficient timing, but given the heterogeneity, a uniform subsidy or liability would never be able to induce the efficient adoption path. Even if subsidy or liability are group-based, it would be very challenging, if not impossible, to set the right number for every group such that the adoptions would happen right at the socially optimal timing. Moreover, these policies miss the root of the problem of a market failure. The reason these policies might be helpful is not for externality but for the unavailability of security-related information. A better approach, apparently, would be addressing the information asymmetry directly.

Waves of legislative efforts have been made to transform firms' private information on security breaches and security practices into *publicly available* information.²⁰ The Cybersecurity Information Sharing Act (CISA), enacted in 2015, aims to "improve cybersecurity in the United States through enhanced sharing of information about cybersecurity threats" (Tran, 2016). Section 5 of the Act establishes procedures for the government to facilitate information sharing about cyber threats and incidents between corporate entities, between corporate entities and the government, and between different government agencies. Section 6 of the Act provides liability protections for private entities that monitor the information system and share cyber threat indicators and defen-

²⁰There are also industry efforts for firms to share security information with each other (Laube and Böhme, 2016; Pala and Zhuang, 2019). Such organizations include Security-Based Information Sharing Organization (SB/ISO), "Computer Emergency Response Teams" (CERT), Information Sharing Analysis Centers (ISAC). Voluntary disclosure so far has been met with mixed success and some authors argue for misaligned incentive problems (Kannan and Telang, 2005; Arora et al., 2008).

sive measures in good faith.

Prior to federal law, all fifty U.S. states had laws requiring companies to notify individuals if their personal information was compromised in a data breach. These laws vary by state but typically require notification to be made within a certain time-frame and include required information about the breach. A primary goal of the breach disclosure laws is to incentivize firms to invest and improve their security practices. The idea is simple: since mandatory disclosure imposes a variety of costs on the firms (e.g., costs of customer support, costs of cleaning up the system, reputation loss, etc.), firms can avoid these costs if they invest in preventing data breaches in the first place. [Romanosky et al. \(2011\)](#) succinctly term this as the “sunlight effect”: “by highlighting a firm’s poor security measures, legislators hope to create an incentive for all firms (even though that have not been breached) to improve the protection of their data, thereby ‘disinfecting’ themselves of shoddy security practices.” Senator Smitian, who co-authored California’s breach disclosure law, wrote in [Simitian \(2009\)](#) that one primary purpose of the bill was to “provide an incentive to those responsible for public and private databases to improve their security (and thus reduce the risk for all of us).” This investment effect of solving information asymmetry has been, to some extent, validated by emerging empirical studies, which show that the breach disclosure law leads to increased investment in data encryption ([Miller and Tucker, 2011](#)) and web server upgrades ([Murciano-Goroff, 2019](#)).

9 Conclusion

In this paper, I present a series of continuous-time models of security adoption and use them to analyze the nature of market failure in the industry. In the homogeneous model and five extended models, the equilibrium adoption path is proved to be the socially optimal path. The efficiency result would break down, however, if information asymmetry is introduced. So in this market, externalities alone do not necessarily cause market failure. Coupled with information asymmetry, externalities would become a problem that requires government correction. Explanations are provided as to why this is true and why the result has policy significance.

Throughout the paper, I refer to firms as my unit of analysis, but the analysis can also be applied to public sector, such as the federal agencies that aims to adopt cost-effective security measures, or sophisticated users who understand the security risk and can defend themselves. I should also add a qualification on the kind of externalities I consider in this paper: security-related

externality. For markets with built-in non-security related externality (e.g., cross-side externality in two-sided markets), the market adoption of security might be inefficient for non-security reasons.

21

The models in this paper provide a framework for dynamic welfare analysis of the security market. The models generate testable predictions on firms' security adoption behavior, which may guide further empirical studies. I list four key empirical implications.

- S-adoption curve: adoption is initially slow and accelerates exponentially after a critical mass of breaches occurs.
- Heterogeneity of adopters: all other things equal, firms with higher vulnerability or higher valuation of IT systems (e.g., financial institutions, e-commerce platforms) adopt earlier. Firms with an in-house security team adopt earlier than those that outsource.
- One can empirically estimate the breach hazard function over time and test for its monotonicity (e.g., by conducting survival analysis such as the Cox model), which is a critical precondition of the efficiency result.
- Role of public information: in settings with private breach risk, security adoption is delayed relative to cases where breaches are publicly disclosed and firms observe others' incidents.

I also list some further considerations that can be evaluated using this framework. Reassessing these possibilities can be a rich line of research in the future.

- Strategic attacker: in the paper, attackers operate at constant scale (α, β) . If the attacking rates $\alpha(t)$ and $\beta(t)$ are weakly increasing over time, the efficiency results would still hold.²² Strategic attackers, however, may adjust the intensity of attacks as a best response to the firms' adoption strategy.²³
- Intra-organization friction: it is common for economic models to start with firms' inter-organizational interactions in which firms are profit maximizers without internal frictions.

²¹In related papers [Arce \(2020\)](#) and [Zhang and Arce \(2025\)](#), the authors consider the security provision of two-sided platforms.

²²For example, the models presented can also accommodate the scenario of trusted relationships (e.g., account credentials) with partner firms, in which insider threats arriving through this vector will not be stopped by strengthening defense against external attackers. In this case, a firm's risk of an indirect attack β is the same whether it invests against direct attacks α or not. As long as the direct attack rate $\alpha(t)$ does not decrease over time, which satisfies the increasing hazard rate condition, the results hold.

²³See [Arce \(2018\)](#) for modeling attacker's decision based on firms' market share. See [Khouzani et al. \(2011\)](#) and [Bensoussan et al. \(2010\)](#) for works on the differential games approach.

Firms' intra-organizational structure, however, can also affect the resulting level of security. For instance, within a company, the emergency response team, information technology department, and sales department all have well-defined goals that might not align perfectly with the managerial board. This can cause principal-agent problems that further distort security investment from the optimal level.

Externalities and information asymmetry are considered two primary sources of market failure in private security decisions. The findings in this paper establish a welfare benchmark and naturally suggest a direction for future research: how does the security market deviate from this benchmark? And which market friction should legislators prioritize? I provide one such argument for prioritizing information asymmetry over externalities. From a positive economics perspective, my findings might provide an explanation for why federal and state governments prioritize breach disclosure law over public subsidy programs. Breach disclosure laws do seem to be popular at all levels of administration in the US, as can be seen in the CISA, fifty state laws, and other legislative efforts. Purely externality-based interventions such as subsidy, mandate, or liability, on the other hand, remain mostly on the discussion table. This is consistent with the view in Section 8 that sufficient public information is a prerequisite for the market to thrive.

In general, there are multiple sources of friction in the market of information security (Anderson and Moore, 2006). Designing security policies in the presence of multiple frictions is by no means an easy task. Policy proposals are usually justified by either one particular market failure or a combination of them, but more work needs to be done to assess the *relative importance* of each friction.

References

- Alesina, Alberto and Allan Drazen**, "Why Are Stabilizations Delayed?," *American Economic Review*, 1991, 81 (5), 1170–88.
- Anderson, Ross**, "Why information security is hard-an economic perspective," in "Seventeenth annual computer security applications conference" IEEE 2001, pp. 358–365.
- **and Tyler Moore**, "The economics of information security," *science*, 2006, 314 (5799), 610–613.
- , **Rainer Böhme, Richard Clayton, and Tyler Moore**, "Security economics and European policy," *Managing information risk and the economics of security*, 2009, pp. 55–80.
- Arce, Daniel**, "Cybersecurity For Defense Economists," *Defence and Peace Economics*, 2022, pp. 1–21.
- Arce, Daniel G**, "Malware and market share," *Journal of Cybersecurity*, 2018, 4 (1), ty010.
- , "Cybersecurity and platform competition in the cloud," *Computers & Security*, 2020, 93, 101774.
- Arora, Ashish, Rahul Telang, and Hao Xu**, "Optimal policy for software vulnerability disclosure," *Management Science*, 2008, 54 (4), 642–656.
- Arrow, Kenneth J**, "The Organization of Economic Activity: Issues," *The Analysis and Evaluation of Public Expenditures: the PPB System: pt*, 1969, 1.
- Bensoussan, Alain, Murat Kantarcioglu, and SingRu Hoe**, "A game-theoretical approach for finding optimal strategies in a botnet defense model," in "Decision and Game Theory for Security: First International Conference, GameSec 2010, Berlin, Germany, November 22-23, 2010. Proceedings 1" Springer 2010, pp. 135–148.
- Bohme, Rainer and Tyler Moore**, "The iterated weakest link," *IEEE Security & Privacy*, 2010, 8 (1), 53–55.
- Camp, Jean and Catherine Wolfram**, "Pricing security: A market in vulnerabilities," in "Economics of information security," Springer, 2004, pp. 17–34.
- Chen, Frederick and Flavio Toxvaerd**, "The economics of vaccination," *Journal of theoretical biology*, 2014, 363, 105–117.
- Coase, R. H.**, "The Problem of Social Cost," *The Journal of Law Economics*, 1960, 3, 1–44.

- Committee, President's Information Technology Advisory**, *Cyber security: A crisis of prioritization*, National Coordination Office for Information Technology Research and Development, 2005.
- Cordes, Joseph J**, "An overview of the economics of cybersecurity and cybersecurity policy," 2011.
- Cornière, Alexandre De and Greg Taylor**, "A model of information security and competition," *Marketing Science*, 2024.
- Eeten, Michel JG Van and Johannes M Bauer**, "Economics of malware: Security decisions, incentives and externalities," 2008.
- Fedele, Alessandro and Cristian Roner**, "Dangerous games: A literature review on cybersecurity investments," *Journal of Economic Surveys*, 2022, 36 (1), 157–187.
- Francis, Peter J**, "Dynamic epidemiology and the market for vaccinations," *Journal of Public Economics*, 1997, 63 (3), 383–406.
- Gandal, Neil**, "An Introduction to Key Themes in the Economics of Cyber Security," in "Cyber Warfare and Cyber Terrorism," IGI Global, 2007, pp. 78–82.
- Gersovitz, Mark and Jeffrey S Hammer**, "The Economical Control of Infectious Diseases," *The Economic Journal*, 2004, 114 (492), 1–27.
- Gordon, Lawrence A and Martin P Loeb**, "The economics of information security investment," *ACM Transactions on Information and System Security (TISSEC)*, 2002, 5 (4), 438–457.
- , —, and **William Lucyshyn**, "Information security expenditures and real options: A wait-and-see approach," *Computer Security Journal*, 2003, 19 (2).
- Grossklags, Jens, Nicolas Christin, and John Chuang**, "Secure or insure? A game-theoretic analysis of information security games," in "Proceedings of the 17th international conference on World Wide Web" 2008, pp. 209–218.
- Herley, Cormac**, "So long, and no thanks for the externalities: the rational rejection of security advice by users," in "Proceedings of the 2009 workshop on New security paradigms workshop" 2009, pp. 133–144.
- ichi Tatsumi, Ken and Makoto Goto**, "Optimal timing of information security investment: A real options approach," in "Economics of information security and privacy," Springer, 2010, pp. 211–228.

- Kannan, Karthik and Rahul Telang**, "Market for software vulnerabilities? Think again," *Management science*, 2005, 51 (5), 726–740.
- Karyotis, Vasileios and MHR Khouzani**, *Malware diffusion models for modern complex networks: theory and applications*, Morgan Kaufmann, 2016.
- Katz, Michael L and Carl Shapiro**, "Network externalities, competition, and compatibility," *The American economic review*, 1985, 75 (3), 424–440.
- Keeling, Matt J and Pejman Rohani**, *Modeling infectious diseases in humans and animals*, Princeton University Press, 2008.
- Khouzani, MHR, Saswati Sarkar, and Eitan Altman**, "A dynamic game solution to malware attack," in "2011 Proceedings IEEE INFOCOM" IEEE 2011, pp. 2138–2146.
- Kobayashi, Bruce H**, "An economic analysis of the private and social costs of the provision of cybersecurity and other public security goods," *Sup. Ct. Econ. Rev.*, 2006, 14, 261.
- Koutsoupias, Elias and Christos Papadimitriou**, "Worst-case equilibria," in "Annual symposium on theoretical aspects of computer science" Springer 1999, pp. 404–413.
- Kunreuther, Howard and Geoffrey Heal**, "Interdependent security," *Journal of risk and uncertainty*, 2003, 26, 231–249.
- Lam, Wing Man Wynne**, "Attack-prevention and damage-control investments in cybersecurity," *Information Economics and Policy*, 2016, 37, 42–51.
- Laube, Stefan and Rainer Böhme**, "The economics of mandatory security breach reporting to authorities," *Journal of Cybersecurity*, 2016, 2 (1), 29–41.
- Law, Samuelson**, "Technology, & Public Policy Clinic," "Security Breach Notification Laws: Views from Chief Security Officers," *University of California-Berkeley School of Law*, 2007.
- Lelarge, Marc**, "Economics of malware: Epidemic risks model, network externalities and incentives," in "2009 47th annual Allerton conference on communication, control, and computing (Allerton)" IEEE 2009, pp. 1353–1360.
- Li, Zhen, Qi Liao, and Aaron Striegel**, "Botnet economics: uncertainty matters," *Managing information risk and the economics of security*, 2009, pp. 245–267.
- Lindahl, Erik**, "Just taxation—a positive solution," in "Classics in the theory of public finance," Springer, 1958, pp. 168–176.

- Meade, James E**, "External economies and diseconomies in a competitive situation," *The economic journal*, 1952, 62 (245), 54–67.
- Miller, Amalia R and Catherine E Tucker**, "Encryption and the loss of patient data," *Journal of Policy Analysis and Management*, 2011, 30 (3), 534–556.
- Moore, Tyler and Richard Clayton**, "Evil searching: Compromise and recompromise of internet hosts for phishing," in "International Conference on Financial Cryptography and Data Security" Springer 2009, pp. 256–272.
- Murciano-Goroff, Raviv**, "Do data breach disclosure laws increase firms' investment in securing their digital infrastructure," in "Workshop on the Economics of Information Security" 2019, pp. 1–39.
- Murdoch, Steven J, Saar Drimer, Ross Anderson, and Mike Bond**, "Chip and PIN is Broken," in "2010 IEEE Symposium on Security and Privacy" IEEE 2010, pp. 433–446.
- Namestnikov, Yuri**, "The economics of botnets," *Analysis on Viruslist. com, Kapersky Lab*, 2009.
- Pala, Ali and Jun Zhuang**, "Information sharing in cybersecurity: A review," *Decision Analysis*, 2019, 16 (3), 172–196.
- Pang, Min-Seok and Huseyin Tanriverdi**, "Security breaches in the US federal government," in "Workshop on the Economics of Information Security" 2017.
- Papadimitriou, Christos**, "Algorithms, games, and the internet," in "Proceedings of the thirty-third annual ACM symposium on Theory of computing" 2001, pp. 749–753.
- Powell, Benjamin**, "Is cyberspace a public good-evidence from the financial services industry," *JL Econ. & Pol'y*, 2005, 1, 497.
- Romanosky, Sasha, Rahul Telang, and Alessandro Acquisti**, "Do data breach disclosure laws reduce identity theft?," *Journal of Policy Analysis and Management*, 2011, 30 (2), 256–286.
- Schwartz, Paul M and Edward J Janger**, "Notification of data security breaches," *Mich. L. Rev.*, 2006, 105, 913.
- Sen, Ravi, Ajay Verma, and Gregory R Heim**, "Impact of cyberattacks by malicious hackers on the competition in software markets," *Journal of Management Information Systems*, 2020, 37 (1), 191–216.

Simitian, Joseph, “How a bill becomes a law, really,” *Berkeley Tech. LJ*, 2009, 24, 1009.

Sivagnanam, Amutheezan, Soodeh Atefi, Afiya Ayman, Jens Grossklags, and Aron Laszka, “On the benefits of bug bounty programs: A study of chromium vulnerabilities,” in “Workshop on the Economics of Information Security (WEIS),” Vol. 10 2021.

Tran, Jasper L, “Navigating the cybersecurity act of 2015,” *Chap. L. Rev.*, 2016, 19, 483.

Varian, Hal, “System reliability and free riding,” *Economics of information security*, 2004, pp. 1–15.

Yu, Wei, Nan Zhang, Xinwen Fu, and Wei Zhao, “Self-disciplinary worms and countermeasures: Modeling and analysis,” *IEEE Transactions on Parallel and Distributed Systems*, 2009, 21 (10), 1501–1514.

Zhang, Pengfei and Daniel G Arce, “Mind the Gaps: Platforms and (Cyber) Security,” *Available at SSRN 5185857*, 2025.